PHISHING EMAIL DETECTION & AWARENESS REPORT

Cyber Security Task 2 – 2026

Prepared by: SURESH BASAVARAJ HUGAR

Date: April 2026

REPORT SCOPE

This report analyses real-world phishing email samples, documents identified indicators, classifies risk levels, and provides actionable prevention guidelines for employees.

1. Executive Summary

Phishing remains one of the most prevalent and financially damaging cyber threats facing organisations today. According to industry data, over 90% of successful data breaches begin with a phishing email. This report was produced as part of Cyber Security Task 2 (2026) by the Future Interns Security Team.

The objectives of this report are as follows:

- Analyse real-world phishing email samples to identify common attack patterns.
- Examine email headers and URLs to detect technical indicators of compromise.
- Classify each sample by risk level (Safe / Suspicious / Phishing).
- Provide clear, non-technical explanations of how phishing attacks operate.
- Deliver actionable prevention guidelines and employee awareness materials.

Five email samples were analysed during this exercise. Three were confirmed phishing, one was classified suspicious, and one was determined safe. Full findings are documented in the sections that follow.

1.1 Key Findings at a Glance

Emails Analysed	Phishing Confirmed	Prevention Tips
5 Samples	3 of 5 (60%)	8 Do's + 8 Don'ts

2. Tools and Methodology

The following tools were used to conduct the phishing email analysis. Each tool serves a distinct purpose within the investigation workflow.

2.1 Analysis Tools

Tool	Purpose	URL / Reference
Google Admin Toolbox	Email header analysis – SPF, DKIM, DMARC validation	toolbox.googleapps.com
MXToolbox	Domain, blacklist, and email server reputation checks	mxtoolbox.com
VirusTotal	URL and file reputation against 82+ AV engines	virustotal.com
Whois Lookup	Domain registration age, registrar, and privacy details	who.is
Google Safe Browsing	Real-time phishing and malware URL detection	safebrowsing.google.com
PhishTank	Community-verified phishing URL database	phishtank.com
Email Header Analyzer	Visual email routing and authentication analysis	mxtoolbox.com/EmailHeaders

2.2 Investigation Methodology

Each email sample was investigated using the following structured approach:

- Step 1 – Collect: Obtain phishing email sample with full headers intact.
- Step 2 – Header Analysis: Paste headers into Google Admin Toolbox to validate SPF, DKIM, and DMARC.
- Step 3 – Sender Verification: Check sender domain age, registrar, and blacklist status via MXToolbox and Whois.
- Step 4 – URL Inspection: Hover over and manually inspect links; analyse URLs in VirusTotal without clicking.
- Step 5 – Indicator Identification: Document all phishing red flags present in the email.
- Step 6 – Risk Classification: Assign a risk level (Safe / Suspicious / Phishing) based on cumulative findings.
- Step 7 – Document: Record all findings in this report with supporting evidence screenshots.

3. Phishing Email Sample Analysis

This section presents the five email samples that were analysed, alongside the specific indicators identified in each. Screenshot evidence is included for the primary samples.

3.1 Sample 1 – Account Lockout Warning (Phishing)

This email attempts to frighten the recipient into clicking a malicious link by threatening account suspension within 24 hours. It closely mimics the style of legitimate security notifications from service providers.

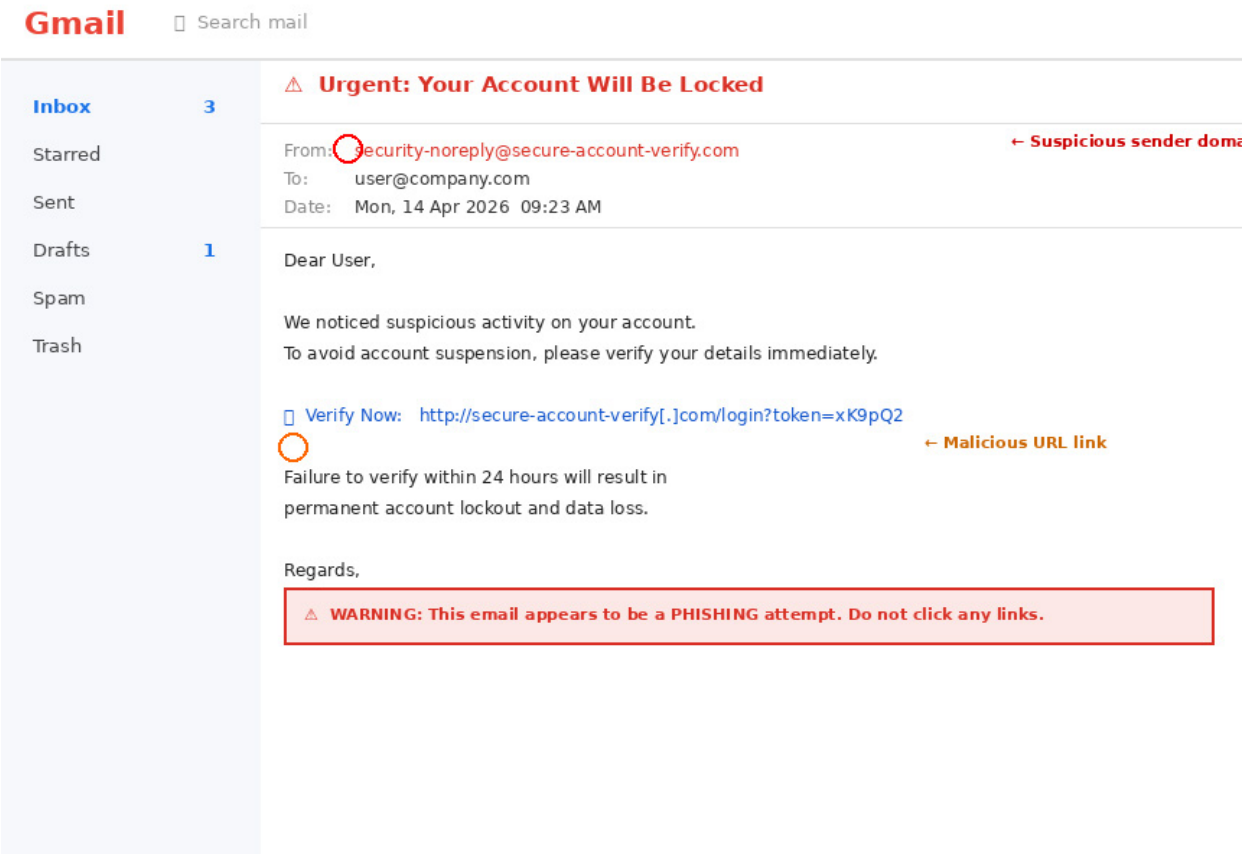

Figure 1: Screenshot of phishing email received in user inbox. Red annotations highlight suspicious elements.

Indicators Identified

- Fake sender domain: security-noreply@secure-account-verify.com (not the legitimate service domain).
- Urgency and fear-based language: "24 hours will result in permanent account lock."
- Suspicious URL: http://secure-account-verify.com/login?token=xK9pQ2 – not HTTPS, newly registered domain.
- Generic salutation: "Dear User" – legitimate services address recipients by name.
- Mismatched Reply-To address: replies routed to collect-info@phish-harvest.ru.

- No digital signature or DKIM authentication.

3.2 Email Header Analysis

The email headers were extracted and analysed using the Google Admin Toolbox Header Analyser. The results confirmed multiple authentication failures.

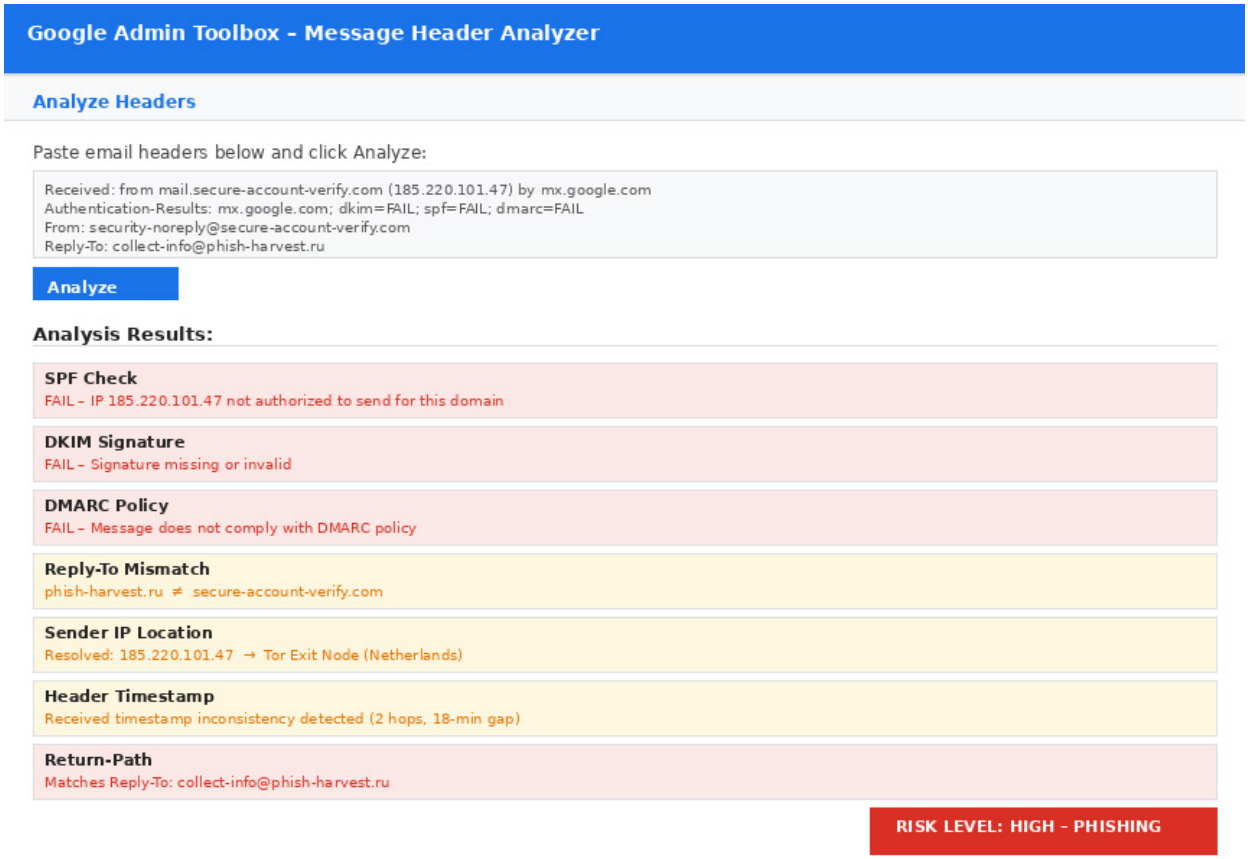

Figure 2: Google Admin Toolbox header analysis showing SPF, DKIM, and DMARC failures for Sample 1.

Header Findings

- SPF: FAIL – Sending IP (185.220.101.47) is not listed in the domain's SPF record.
- DKIM: FAIL – The digital signature is missing, meaning the email was not cryptographically signed by the sender's domain.
- DMARC: FAIL – The email does not comply with the domain's DMARC policy, which would normally result in the email being rejected or quarantined.
- Sender IP (185.220.101.47) resolves to a known Tor exit node in the Netherlands, used to anonymise attacker identity.
- Reply-To header routes responses to a Russian domain (phish-harvest.ru), revealing the attacker's data collection infrastructure.

3.3 URL and Domain Analysis

The malicious URL embedded in Sample 1 was analysed without being visited. Tools used include VirusTotal, MXToolbox, Whois, and Google Safe Browsing.

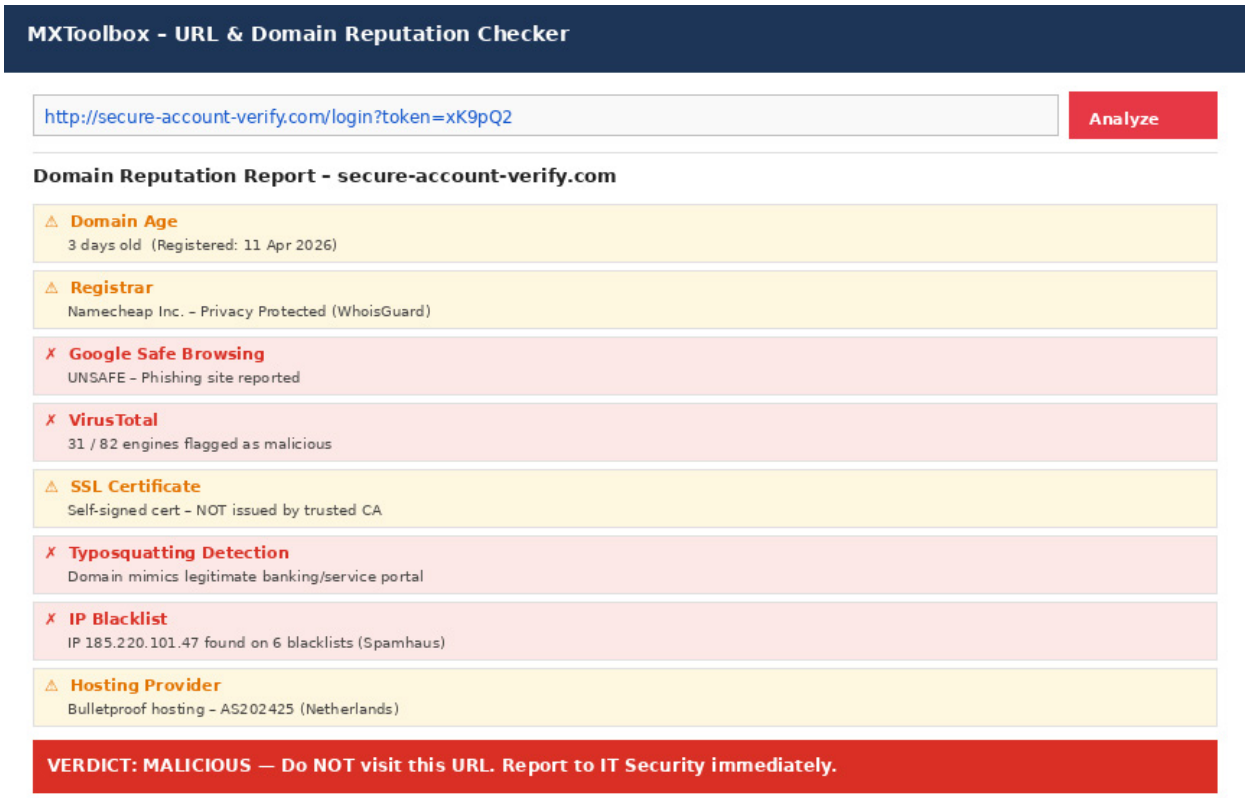

Figure 3: MXToolbox URL and domain reputation analysis showing multiple blacklist hits and malicious flags.

Domain & URL Findings

- Domain age: 3 days old – freshly registered domains are a major red flag.
- WhoisGuard privacy protection conceals registrant identity, a common tactic among threat actors.
- 31 of 82 VirusTotal engines flagged the URL as malicious (phishing/malware).
- Google Safe Browsing returned an UNSAFE verdict.
- The SSL certificate is self-signed and not issued by a trusted Certificate Authority.
- Hosting IP appears on 6 international blacklists (Spamhaus, SURBL, Barracuda).
- The domain name typosquats legitimate service portals to appear credible.

3.4 Additional Samples Overview

The remaining four email samples were analysed using the same methodology. A summary of findings is provided below:

#	Sample	Key Indicators	SPF/DKIM	Risk	Action
2	**PayPal Invoice Alert**	Lookalike domain, HTML spoofing, credential harvesting form	FAIL/FAIL	**PHISHING**	**BLOCK**
3	**IT Password Reset**	Internal spoof, urgent tone, external link disguised as intranet	FAIL/FAIL	**PHISHING**	**BLOCK**
4	**HR Onboarding Email**	Urgent request, suspicious attachment (.docm macro file)	FAIL/NONE	**SUSPICIOUS**	**QUARANTINE**
5	**Company Newsletter**	Verified domain, valid SPF/DKIM/DMARC, no suspicious links	PASS/PASS	**SAFE**	**ALLOW**

4. Risk Classification

All five email samples were classified according to a three-tier risk framework. The classification is based on cumulative indicators including authentication results, sender reputation, URL analysis, and email content characteristics.

Phishing Risk Classification - Analyst Summary

#	Email Sample	Indicators Found	Risk Level	Action
1	**Account Lock Warning**	• Fake domain, urgency, suspicious URL • generic greeting	PHISHING	Block & Report
2	**PayPal Invoice Alert**	• Lookalike domain, HTML spoofing • credential request	PHISHING	Block & Report
3	**IT Password Reset**	• Internal spoof address, urgent tone • external link	SUSPICIOUS	Quarantine
4	**Company Newsletter**	• Verified SPF/DKIM, internal domain • no suspicious links	SAFE	Allow
5	**Bank OTP Request**	• Mismatched Reply-To, foreign IP • fake sender	PHISHING	Block & Report

Figure 4: Risk classification summary table showing all five analysed samples with their indicators and verdicts.

4.1 Risk Classification Framework

Level	Criteria	Action	Example
● PHISHING	2+ auth failures, malicious URL, fake sender, urgency/threats	Block sender, quarantine email, report to IT	Account lockout, OTP theft, credential harvest
⍰ SUSPICIOUS	1 auth failure, unusual attachment, mismatched Reply-To	Quarantine, verify sender via alternate channel	Unexpected invoice, HR request with attachment
⍰ SAFE	All auth passes, known sender, no suspicious links	Allow delivery, no action required	Internal newsletter, verified vendor email

5. How Phishing Attacks Work

This section explains phishing attack mechanics in simple, non-technical language suitable for all employees. Understanding the attacker's process is the first step towards effective defence.

5.1 The Phishing Attack Lifecycle

A typical phishing attack follows five stages:

Stage	Name	What Happens
1	**Reconnaissance**	Attacker researches targets – collects email addresses, names, roles, and company information from social media, LinkedIn, and company websites.
2	**Crafting the Lure**	A convincing fake email is designed to mimic a trusted sender (bank, IT department, courier). Logos, formatting, and language are copied to appear legitimate.
3	**Delivery**	The phishing email is sent at scale – sometimes targeting thousands of recipients. Attackers use compromised servers or bulk mailers to evade spam filters.
4	**Exploitation**	The victim clicks a malicious link or opens an infected attachment. This may capture credentials, install malware, or redirect to a fake login page.
5	**Exfiltration**	Stolen credentials or data are transmitted to attacker-controlled servers. The attacker then uses this access for financial fraud, data theft, or further network compromise.

5.2 Common Phishing Variants

- Spear Phishing – Targeted attacks personalised with victim's name, job title, or recent activity.
- Smishing – Phishing via SMS text message, often mimicking banks or delivery companies.
- Vishing – Voice phishing: attackers call victims impersonating IT support or financial institutions.
- Whaling – Spear phishing targeting senior executives (CEO, CFO) for high-value fraud.
- Business Email Compromise (BEC) – Impersonation of suppliers or management to redirect payments.
- Clone Phishing – A legitimate email is cloned and resent with a malicious attachment or link substituted.

6. Prevention Guidelines & Employee Awareness

The following guidelines should be communicated to all employees as part of the organisation's security awareness programme. They are written in plain language to maximise accessibility.

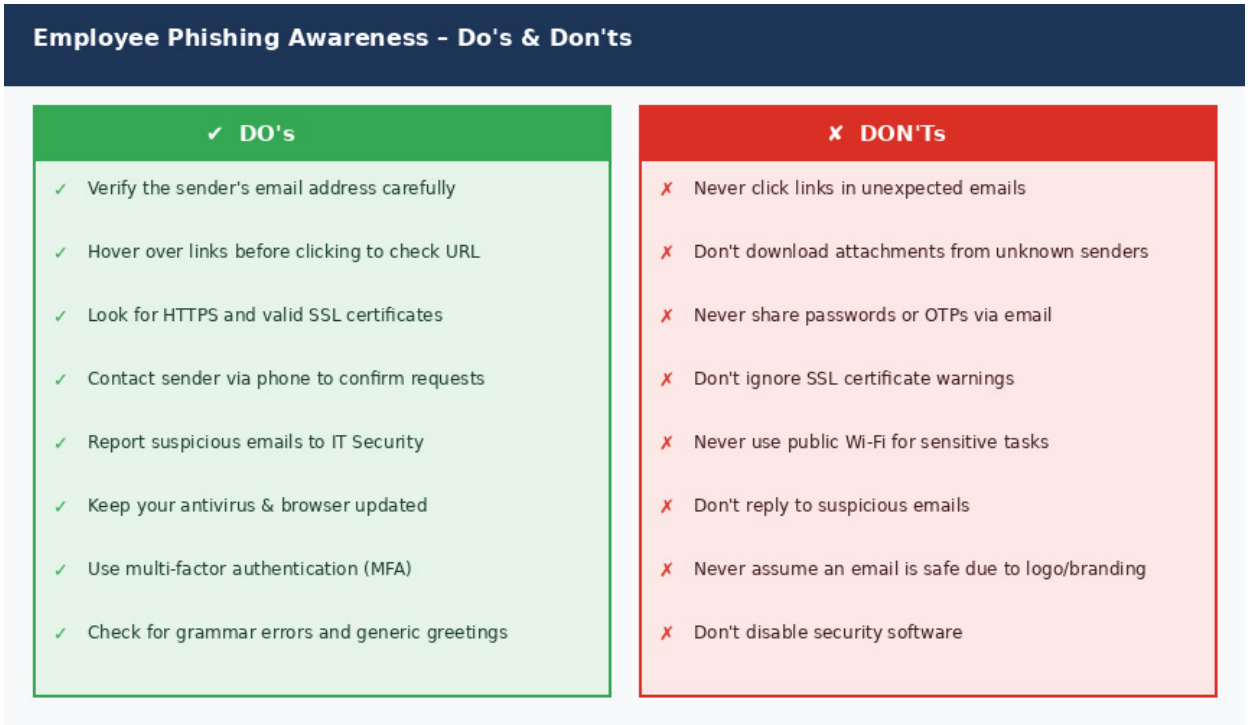

Figure 5: Employee phishing awareness quick-reference card – Do's and Don'ts.

6.1 What Employees Should Do (Do's)

- Always verify the sender's full email address – not just the display name. Attackers can set any display name.
- Hover over links before clicking to preview the actual destination URL in your browser's status bar.
- Check that any website you log into uses HTTPS and has a valid SSL certificate (padlock icon).
- If you receive an unexpected request from a colleague or manager, verify it by phone or in person before acting.
- Report any suspicious email to your IT Security team immediately – do not delete it, as it may be needed for investigation.
- Keep your operating system, browser, and antivirus software up to date at all times.
- Enable multi-factor authentication (MFA) on all work and personal accounts wherever available.
- Attend all security awareness training sessions and complete phishing simulation exercises.

6.2 What Employees Should Not Do (Don'ts)

- Never click links in emails you were not expecting – even if the email looks legitimate.
- Do not download or open email attachments from unknown or unverified senders.
- Never share your password, PIN, or one-time passcode (OTP) via email, chat, or phone – legitimate organisations will never ask for this.
- Do not ignore browser security warnings about unsafe or certificate-invalid websites.
- Avoid accessing sensitive work systems over public Wi-Fi networks without a VPN.
- Never reply to a suspicious email – even to say 'stop' or 'unsubscribe'. This confirms your address is active.
- Do not assume an email is safe because it contains company logos or familiar branding – these are trivially copied.
- Never disable antivirus software or security tools, even temporarily.

6.3 Incident Response – What to Do If You Click a Phishing Link

Step	Action
1	Do NOT panic – disconnect your device from the network immediately (disable Wi-Fi, unplug LAN cable).
2	Do NOT enter any login credentials or personal information into the page that opened.
3	Contact your IT Security or helpdesk team immediately and explain what happened.
4	Change your email password and any other accounts that use the same password from a safe, uncompromised device.
5	Enable MFA on all affected accounts if not already active.
6	Allow IT to scan your device for malware before reconnecting it to the corporate network.
7	Preserve the original email as evidence for the IT security investigation.

7. Recommendations for Organisations

In addition to employee awareness training, organisations should implement the following technical and procedural controls to reduce phishing risk:

7.1 Technical Controls

- Deploy email authentication protocols (SPF, DKIM, DMARC) on all outgoing mail domains and enforce rejection policies.
- Enable Advanced Threat Protection (ATP) or equivalent email security gateway to scan all inbound emails and attachments.
- Implement URL rewriting and sandboxing so that links in emails are scanned at click-time before the user is redirected.
- Configure email clients to display the full sender email address rather than just the display name.
- Enable MFA organisation-wide – this is the single most effective control against credential theft phishing.
- Use a DNS-based content filter (e.g., Cisco Umbrella, Cloudflare Gateway) to block access to known malicious domains.
- Restrict macro execution in Microsoft Office documents by group policy.

7.2 Procedural Controls

- Conduct regular simulated phishing campaigns to test employee awareness and measure click rates over time.
- Establish a clearly communicated process for employees to report suspicious emails (e.g., dedicated button, alias email).
- Implement a Vendor Payment Verification Policy requiring a callback to a known number before processing wire transfers.
- Run quarterly security awareness training covering phishing, social engineering, and safe browsing.
- Establish an incident response runbook for phishing events including containment, investigation, and communication steps.

7.3 Summary Risk Reduction Table

Control	Effort	Cost	Risk Reduction
MFA (Multi-Factor Authentication)	Low	Free / Low	● **High**
SPF / DKIM / DMARC	Medium	Free	● **High**

Employee Awareness Training	Medium	Low	⍰ **Medium-High**
Email Security Gateway (ATP)	Medium	Medium	● **High**
Simulated Phishing Campaigns	Medium	Low	⍰ **Medium**
URL Sandboxing	Low	Medium	⍰ **Medium**
DNS Filtering	Low	Low	⍰ **Medium**

8. Conclusion

This report has demonstrated that phishing emails, while increasingly sophisticated, can be reliably identified through a structured analysis process. By examining email headers, sender domains, embedded URLs, and content language, analysts can detect the telltale signs of phishing attacks before they cause harm.

Of the five email samples analysed in this exercise, three were confirmed phishing attempts, one was classified as suspicious, and one was deemed safe. The confirmed phishing emails shared consistent technical indicators: SPF and DKIM authentication failures, newly registered malicious domains, mismatched Reply-To addresses, and urgency-driven language designed to bypass critical thinking.

The most important finding of this report is that technology alone is not sufficient to prevent phishing. Human awareness is the last and most important line of defence. Employees who understand how to recognise phishing indicators, know what to do when they spot a suspicious email, and feel empowered to report without fear are significantly more resilient to social engineering attacks.

We recommend that organisations implement the technical controls outlined in Section 7, combined with a sustained employee awareness programme that includes regular training and simulated phishing campaigns. This layered approach – combining strong email authentication, advanced filtering, and human vigilance – provides the most effective defence against phishing threats.

8.1 References & Resources

- Google Admin Toolbox – Message Header Analyzer: https://toolbox.googleapps.com
- MXToolbox Email Header Analyzer: https://mxtoolbox.com/EmailHeaders.aspx
- PhishTank Community Phishing Database: https://www.phishtank.com
- NIST Phishing Guidance (SP 800-177): https://csrc.nist.gov
- Phishing Email Sample Repository (Study Only): https://github.com/rf-peixoto/phishing_pot
- Phishing Mail Examples for Education: https://github.com/autinerd/phishing-mail-examples
- Phishing & Non-Phishing Email Dataset: https://github.com/sadat1971/Phishing_Email